

INTERNAL PRODUCTION MVP

Product Requirements Document

v0.5

ControlCheck Core - secure single-organization pilot

Status: Approved implementation baseline

Release: Internal API-only production MVP

Date: 24 August 2026

Executable authority: Application code, runtime JSON catalogues, and Alembic migrations

Decision: ship one secure internal API replica with bearer-key authentication, a server-fixed tenant, managed PostgreSQL, and persistent workbook storage.

1. Executive summary

ControlCheck Core converts governed EPC project-control workbooks into immutable snapshots, canonical facts, deterministic findings, and traceable evidence. PRD v0.5 promotes the validated Phase 4B backend into a deliberately narrow internal production pilot without changing the 20-rule calculation boundary.

The pilot is secure enough for one controlled organization: all versioned API routes require a bearer API key, tenant identity is fixed server-side, health responses disclose minimal state, and release gates preserve Golden 59 and Boundary zero behavior.

2. Product objective and success

Enable an internal project-controls team to deploy and operate the deterministic ControlCheck workflow on managed infrastructure, while preserving reproducibility, tenant isolation, evidence lineage, and recoverability.

- A reviewed image starts predictably from environment-only configuration.
- Unauthorized callers cannot access any /v1/* operation.
- The client cannot select or override the production organization.
- Database, upload storage, and catalogue readiness are observable without leaking internals.
- Controlled fixtures remain Golden 59 and Boundary zero under strict evaluation.

3. Release scope

Area	In v0.5	Explicitly deferred
Identity	One bearer API key; one fixed organization UUID	JWT/OIDC, users, roles, complete RBAC
Runtime	One non-root container replica	Horizontal scaling and rolling multi-replica writes
Data	Managed PostgreSQL plus mounted persistent workbook volume	S3-compatible object storage and cross-region replication
Product	API-only deterministic analysis and durable query workflow	Frontend, customer self-service, LLM orchestration
Tenancy	One controlled internal organization	Public multi-tenant SaaS onboarding and billing

4. Users and operating model

4.1 Internal analyst

Submits governed workbooks, starts snapshot analysis, reviews findings and evidence, and updates finding status through an approved internal client.

4.2 Production operator

Controls deployment settings, secrets, migrations, backups, restores, API key rotation, image promotion, rollback, and request-ID-led incident diagnostics.

4.3 Engineering reviewer

Approves pull requests only after database, tests, deterministic fixtures, document contracts, and container build gates succeed.

5. Functional requirements

5.1 Runtime configuration

- Production mode is selected only by `CONTROLCHECK_ENV=production`.
- Startup fails when database URL, absolute upload root, readable catalogue, organization UUID, API key, or exact trusted hosts are invalid or missing.
- The API key contains at least 32 characters; maximum upload size is a positive byte count.
- CORS defaults to absent and accepts only explicitly configured exact HTTPS origins.
- Interactive docs and OpenAPI are disabled by default in production.

5.2 Authentication and tenant isolation

- Every /v1/* route requires Authorization: Bearer <key> in production.
- Missing, malformed, or incorrect credentials return a generic 401 error and WWW-Authenticate: Bearer.
- Credential comparison is constant-time and credentials never appear in committed files or response bodies.
- Production tenant identity comes only from CONTROLCHECK_ORGANIZATION_ID; X-Organization-ID is ignored.
- Development retains the tenant header solely as a controlled non-production contract.

5.3 Deterministic workflow

- Preserve the Phase 4B governed-template, immutable-snapshot, raw-lineage, canonical-fact, domain-gating, and durable-evidence contracts.
- Keep calculations, thresholds, severities, finding metrics, and evidence deterministic and independent from any LLM.
- Retain the compatibility workbook audit endpoint during the internal pilot.
- Enforce organization scope on project, snapshot, run, finding, evidence, and status operations.

5.4 Health and safe HTTP behavior

- GET /health/live returns only status=live when the process can answer HTTP.
- GET /health/ready checks database, persistent storage, and catalogue, returning only ready or not_ready.
- The legacy /health response remains during the pilot for compatibility.
- Production accepts only configured hostnames and validates or replaces caller-supplied request IDs.
- Unhandled errors return a generic envelope with a safe request ID and no traceback or dependency detail.

6. API surface

Surface	Purpose	Production access
/health/live	Process liveness	Public; minimal
/health/ready	Database, storage, and catalogue readiness	Public; minimal
/health	Pilot compatibility health	Public
/v1/audits	Stateless governed workbook audit	Bearer key
/v1/organizations/.../projects	Organization-scoped project lifecycle	Bearer key + fixed tenant

Surface	Purpose	Production access
/v1/projects/.../dataset-snapshots	Snapshot ingestion and retrieval	Bearer key + fixed tenant
/v1/.../analysis-runs	Deterministic analysis and history	Bearer key + fixed tenant
/v1/findings/...	Finding, evidence, filters, and status	Bearer key + fixed tenant

7. Deployment and release requirements

1. Build from Python 3.11.9 slim-bookworm and run the application as UID/GID 10001.
2. Apply the single linear Alembic head before Uvicorn starts; production database URL comes from environment configuration.
3. Mount one persistent upload volume at the configured absolute path and operate exactly one replica.
4. Use managed PostgreSQL 16 with TLS, automated backup, restore testing, and credentials held outside Git.
5. Require CI compilation, migrations, Alembic drift check, full pytest, Golden strict, Boundary strict, and Docker build.
6. Promote an immutable reviewed image digest from staging to production.

8. Security and non-functional requirements

Requirement	Acceptance
Confidentiality	No real API keys, database credentials, organization IDs, or private keys in Git, images, logs, or responses.
Isolation	All durable repository access remains organization-scoped; client headers cannot change the production tenant.
Availability	Live and ready probes distinguish process health from dependency readiness; failed readiness returns 503.
Recoverability	Database and workbook-volume backups are restored together and verified through persisted evidence retrieval.
Traceability	Every response carries a safe request ID; deterministic findings retain calculation and source evidence.
Performance	Upload size is bounded at 25 MiB by default; the pilot uses one replica and controlled internal load.
Maintainability	Configuration is validated once, migrations remain linear, and each behavior change includes a regression test.

9. Acceptance criteria

Gate	Required result	Evidence
Configuration	Invalid production settings fail startup	Production settings tests
Authentication	All /v1/* routes reject missing/wrong key with 401	Route enumeration and HTTP tests
Tenant	Client tenant header cannot override configured UUID	Fixed-tenant contract test
HTTP safety	Docs off, host restricted, CORS opt-in, generic 500	Production security tests
Health	Live 200; ready 200 or minimal 503	Dependency readiness tests
Container	Build succeeds; runtime UID 10001; no reload	Image build and inspection
Database	Exactly one head; upgrade and drift check succeed	Alembic CI gate
Engine	Golden 59 with zero FP/FN; Boundary zero	Strict fixture evaluations
Operations	Rotation, restore verification, rollback, and incidents documented	Production runbook

10. Risks and controls

Risk	Control	Residual decision
Shared bearer key has no user attribution	Restricted secret distribution, request IDs, key rotation, internal-only access	Accept for pilot; replace with JWT/RBAC later
Local volume prevents safe horizontal writes	Exactly one replica, persistent mount, paired backup verification	Accept for pilot; move to object storage before scaling
Migration failure blocks startup	CI migration gates, managed backup, reviewed rollback/forward-fix procedure	Fail closed
Controlled fixtures overstate real-world confidence	Label results as synthetic agreement; require customer validation before accuracy claims	No customer accuracy claim
Public readiness can aid reconnaissance	Minimal status only; no dependency names or exceptions	Accept behind HTTPS ingress

11. Deferred roadmap

- JWT/OIDC authentication, named users, role model, and complete RBAC.

- S3-compatible object storage, multi-replica execution, and scalable background jobs.
- Production frontend, customer onboarding, subscription/billing, and public multi-tenancy.
- LLM reasoning that summarizes deterministic finding and evidence payloads without altering rule outcomes.
- Customer-data validation, operational SLOs, and capacity targets based on observed pilot load.

12. Change log

v0.5 - Defines the internal production MVP security boundary, strict runtime configuration, bearer authentication, fixed tenant, safe HTTP behavior, liveness and readiness, managed PostgreSQL, persistent storage, non-root container, CI release gates, operating runbook, and explicit JWT/RBAC/object-storage/frontend deferrals.

Historical PRDs remain immutable. PRD v0.4 continues to describe canonical ingestion; v0.5 adds the production operating boundary without replacing runtime JSON catalogues or executable Alembic migrations.